TICPSH 上海控安

车联网安全赛道培训

Beyond Trust Future Industry

为工业安全赋能

上海工业控制安全创新科技有限公司

培训工程师：沈平、肖博阳



CONTENT
目 录

01 车联网安全赛道简介

02 CAN安全培训

03 应用安全培训

04 AI可信学习参考

PART 1

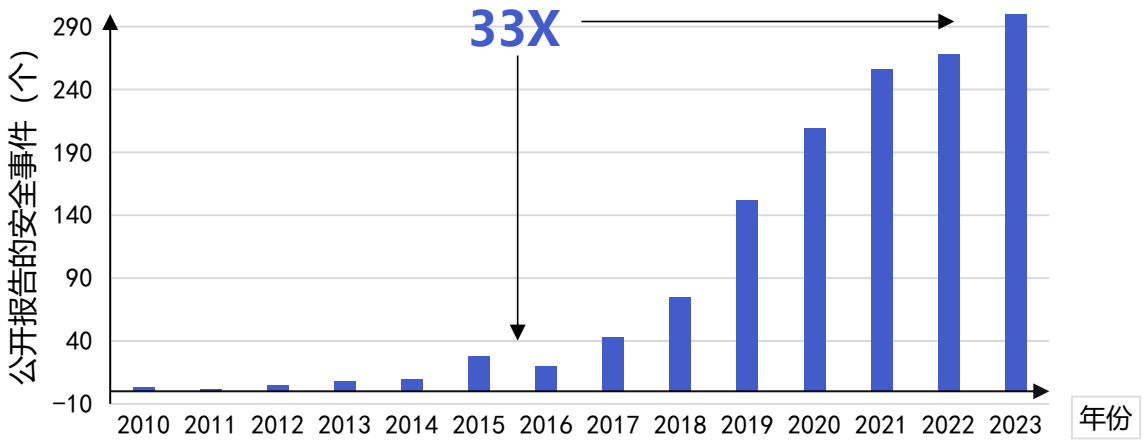
车联网安全赛道简介

Beyond Trust Future Industry

为工业安全赋能

车联网安全背景

2010-2023年汽车网络安全攻击事件



几个典型网络安全事件（黑帽/白帽）

- 2021年5月，腾讯安全研究人员在梅赛德斯-奔驰信息娱乐系统中发现了许多漏洞，这些漏洞可以被利用来入侵车辆。研究人员发现了多个攻击面，包括 JavaScript 引擎、蓝牙堆栈、WiFi 芯片、USB 功能。
- 2021年7月，攻击者设计了一款无线 CAN 总线黑客和开发模块，该模块能够对大众高尔夫汽车的 CAN 总线控制台进行攻击。同时攻击方开源了相应的算法模块。
- 2022年10月，欧洲刑警组织捣毁一个专门窃取汽车的网络犯罪组织，查获超过100万欧元的犯罪资产。该组织是通过一款欺诈性软件，偷偷进入并启动软件系统瞄准的车辆。

汽车网络安全国内外法规及标准

发布时间	名称	类型
2021.3	Uniform provisions concerning the approval of vehicles with regards to cyber security and cyber security management system (R155)	欧盟标准
2021.3	Uniform provisions concerning the approval of vehicles with regards to software update and software updates management system (R156)	欧盟标准
2021.8	ISO/SAE 21434 Road vehicles - Cybersecurity engineering	国际标准
2021.10	GB/T 40861-2021 汽车信息安全通用技术要求	GB推标
2021.10	GB/T 40856-2021 车载信息交互系统信息安全技术要求及试验方法，工业和信息化部	GB推标
2021.10	GB/T 40855-2021 电动汽车远程服务与管理系统信息安全技术要求及试验方法	GB推标
2021.10	GB/T 40857-2021 汽车网关信息安全技术要求及试验方法	GB推标
2024.08	GB 44495-2024 汽车整车信息安全技术要求	**GB强标**
即将发布	汽车软件升级通用技术要求	**GB强标**

汽车网络安全事件频发，国内外出台标准法规规范汽车网络安全，车联网安全保障迫在眉睫

BEYOND TRUST / FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能



Company
Introduction

技术引领的工业安全产业生态服务平台

Technology Driven Service Platform for Trusted Industry

上海工业控制系统安全创新功能型平台是上海市为打造全球科技创新中心首批推动建设的研发与转化功能型平台之一，是上海市建设具有全球影响力的科技创新中心“四梁八柱”的重要部分。

上海工业控制安全创新科技有限公司作为平台的运营实体，聚焦工业控制系统功能安全和信息安全“卡脖子”技术创新和成果转化，面向汽车电子、轨道交通、航空航天等安全攸关行业提供共性服务支撑，致力于打造技术引领的产业生态服务平台。

上海工业控制安全创新科技有限公司-专家领袖



首席科学家
何积丰



首席科学顾问
Joseph Sifakis





首席科学家

何积丰：中国科学院院士、华师大终身教授

国际科学顾问

Joseph Sifakis：2007年图灵奖获得者、法国科学院院士、中科院外籍院士

Moshe Vardi：美国科学院、美国工程院、欧洲科学院等五院院士

战略专家委员会

何积丰院士、褚君浩院士、钱峰院士、沈昌祥院士、杨孟飞院士、褚健教授等19位行业专家

BEYOND TRUST / www.ticpsh.com
FUTURE INDUSTRY 为工业安全赋能

上海工业控制安全创新科技有限公司-核心产品

TICPSH 上海控安

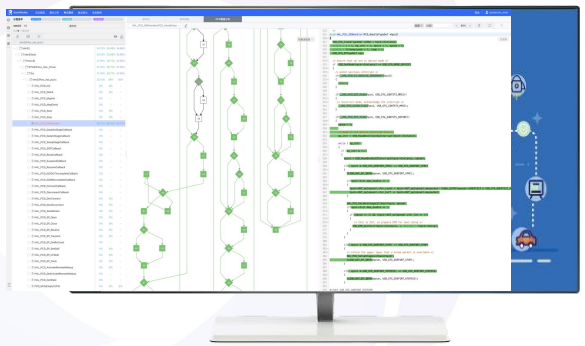
TestGrid 嵌入式软件自动化测试平台

SmartRocket TestGrid

嵌入式软件自动化测试平台

实现对英国Testbed、德国Tessy工具的国产化替代

- C/C++程序的静态分析、单元测试、集成测试、目标机结构覆盖测试平台
- 满足GJB、MISRA等标准对源代码进行质量分析
- 国内首家通过TüV南德认证的自动化测试工具
- **特色优势：高覆盖单元测试、一体化测试平台、简约用户体验、多平台无缝集成**



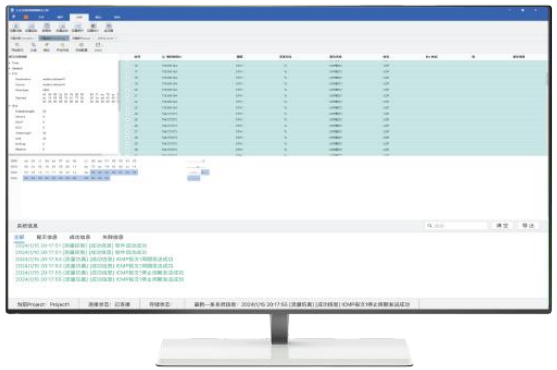
BlitzFuzz 工业互联网协议模糊测试工具

SmartRocket BlitzFuzz

工业互联网协议模糊测试工具

实现对美国Defensics、 Mayhem工具的国产化替代

- 基于模型的设计开发与验证、高可信C代码自动生成
- 支持Ethernet II、Bluetooth、WiFi 、IPv4 、CAN/CANFD 、UDP、TCP、USB、ARP 、SOME/IP 、DoIP 等共 14 种协议
- **特色优势：丰富可拓展构件库、高效易用建模环境、全方位静态检查、动态仿真与验证、自动生成符合国军标的C代码、国产化环境支持**



PeneX 汽车网络安全测试系统

SmartRocket PeneX

汽车网络安全测试系统

全方位汽车网络安全渗透、合规检测

- 包含硬件安全、软件系统安全、车内通信、车外通信、数据安全五大安全测试系统
- 满足国家整车信息安全强制性标准、R155、40855、40856、40857 等多项国际标准
- **特色优势：支持汽车特有CAN、以太网等DoS、模糊测试；支持蓝牙(经典/低功耗)、WIFI(2.4G/5G)安全测试；支持漏洞、敏感信息扫描等**



PeneX Lab

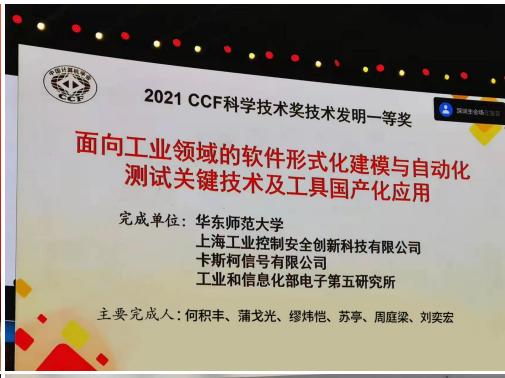


PeneX Lite

上海工业控制安全创新科技有限公司-公司荣誉

- “面向工业领域的软件形式化建模与自动化测试关键技术及工具国产化应用”项目 荣获2021年“中国计算机学会科学技术奖技术发明一等奖”
- 由中国科学院院士、上海控安首席科学家何积丰、总经理蒲戈光教授牵头的《面向重大工业装备核心控制软件的安全可信保障技术及应用》项目摘得“2019年度上海市科技进步奖特等奖”
- 上海控安技术成果荣获“2020年度上海市高新技术成果转化自主创新十强”
- 由上海控安总经理蒲戈光教授牵头的《航天嵌入式软件可信性保障关键技术和应用》项目摘得“2019年度北京市科学技术进步奖一等奖”
- 入选国家工信部第四批产业技术基础公共服务平台名录，上海市仅此一家
- 荣登2023上海高新技术企业创新百强榜、2023上海软件和信息技术服务业高成长百家榜
- 荣获第四届普陀区政府质量奖创新奖
- 入选2021年首批工控安全防护能力贯标咨询机构名单
- 获批设立 博士后科研工作站
- 荣获“2020年网络安全创新产品优秀奖”
- 荣获“第二十二届中国国际高新技术成果交易会优秀产品奖”
- 入选上海市经信委《2021年上海市网络安全产业创新攻关成果目录》













BEYOND TRUST / FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

比赛简介

赛题内容： 汽车CAN总线安全、应用安全、AI可信安全

赛题形式：

	CAN安全	应用安全	AI可信安全
初赛	2实操题	5单选 1实操题	1实操题
决赛	1实操题	1实操题	1实操题

评分机制：

- 单选：选择正确得分、选择错误不得分
- 实操：按步骤得分
- 实操题需要以附件形式，上传详细解题过程（如有代码，需附）
- 最终得分以最后一次提交成绩为准
- 相同得分者，以提交时间进行排名

BEYOND TRUST FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

比 赛 流 程 演 示

题目分为三个部分：

1. 题目描述
2. 答题文件
3. 附件

BEYOND TRUST FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

PART 2

CAN安全培训

Beyond Trust Future Industry

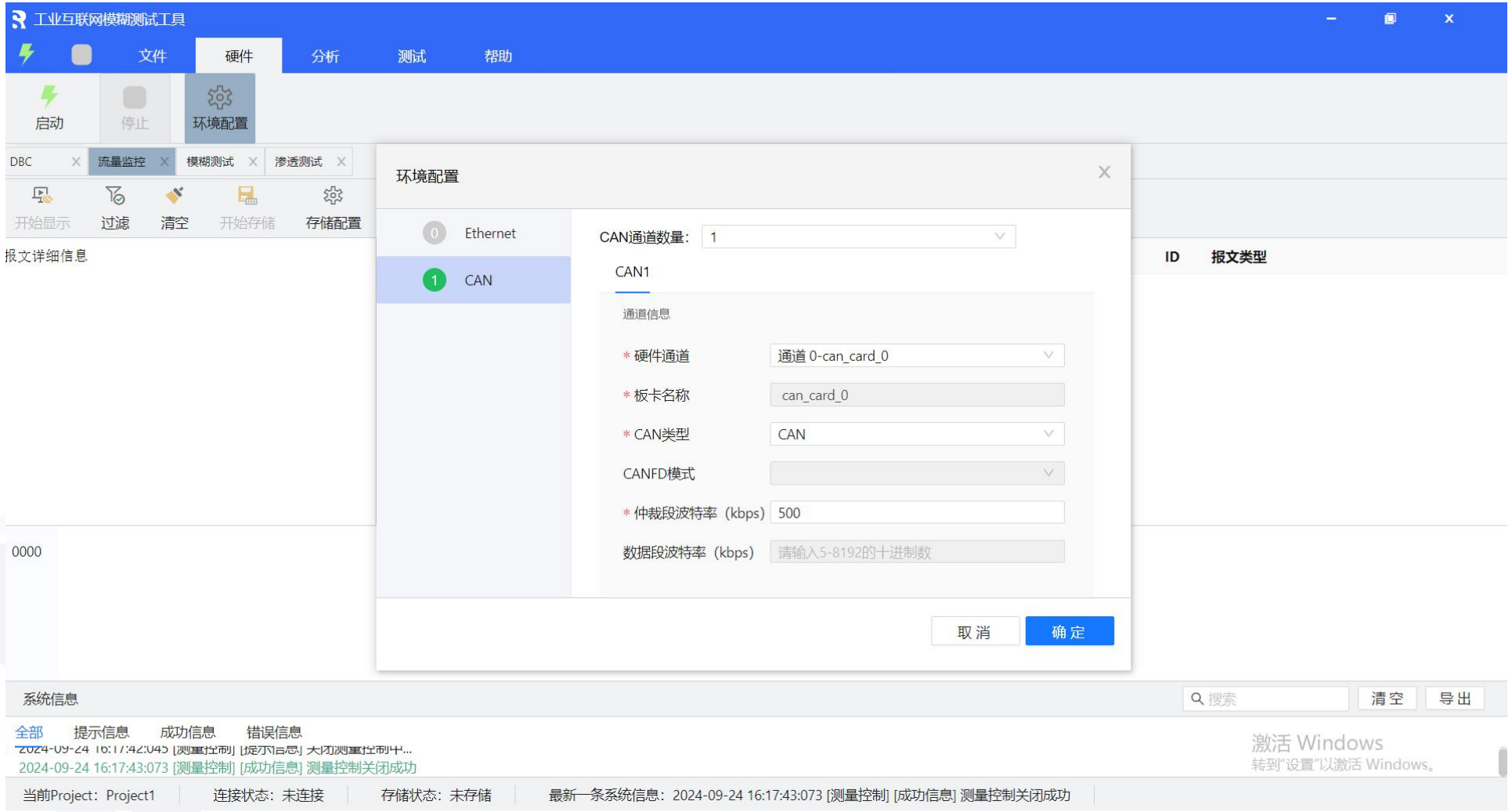
为工业安全赋能

CAN安全比赛范围

- 报文数据帧：包含哪些字段、每个字段的范围
- 多帧传输：多帧传输的规则
- 诊断协议：0x22 DID读取数据 服务
- DBC文件：包含哪些字段，尤其是信号的相关属性
- CAN报文存储文件：blf、asc文件
- 密码学：对称加密

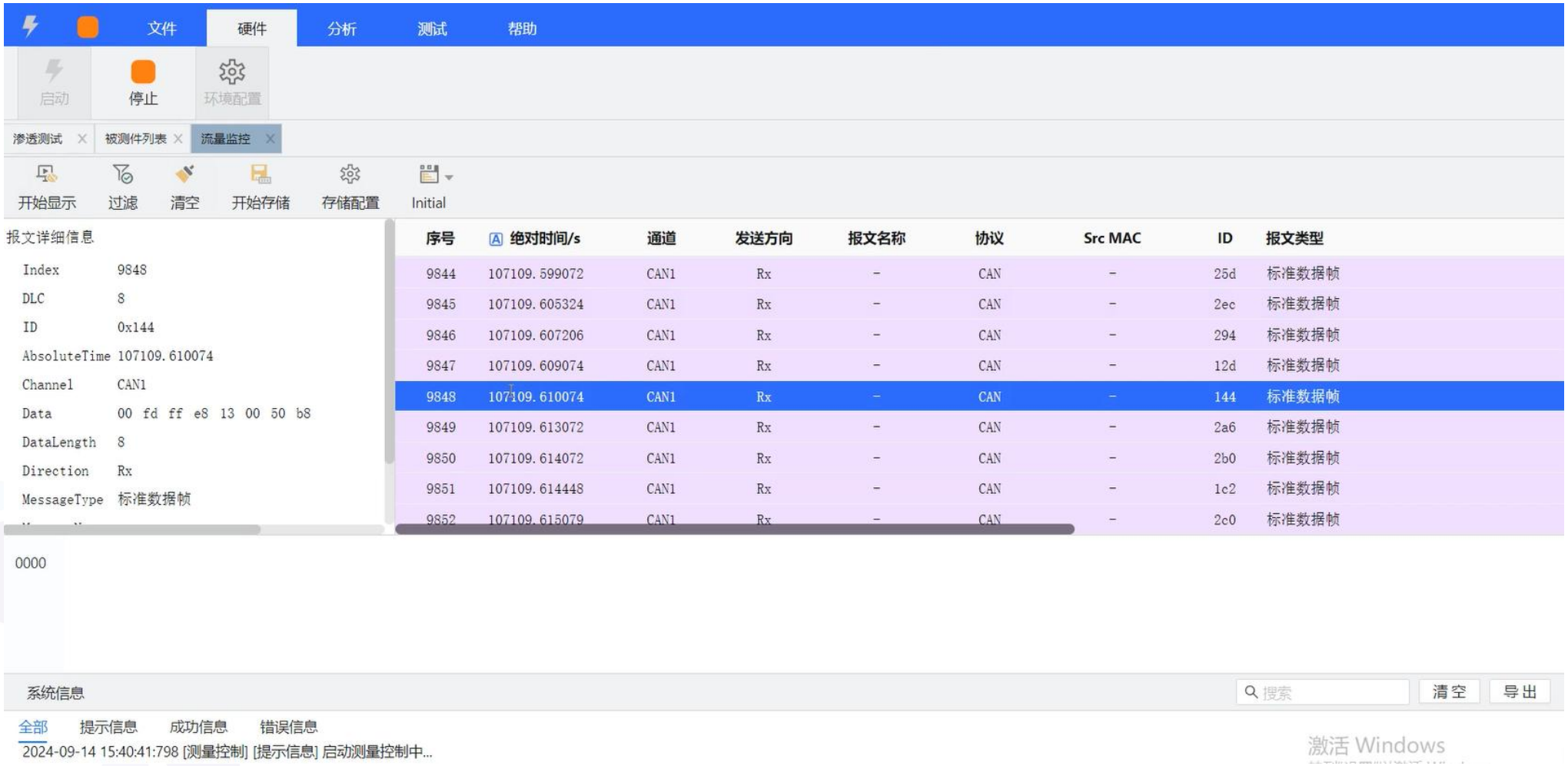
BEYOND TRUST / www.ticpsh.com
FUTURE INDUSTRY 为工业安全赋能

CAN安全实操演示



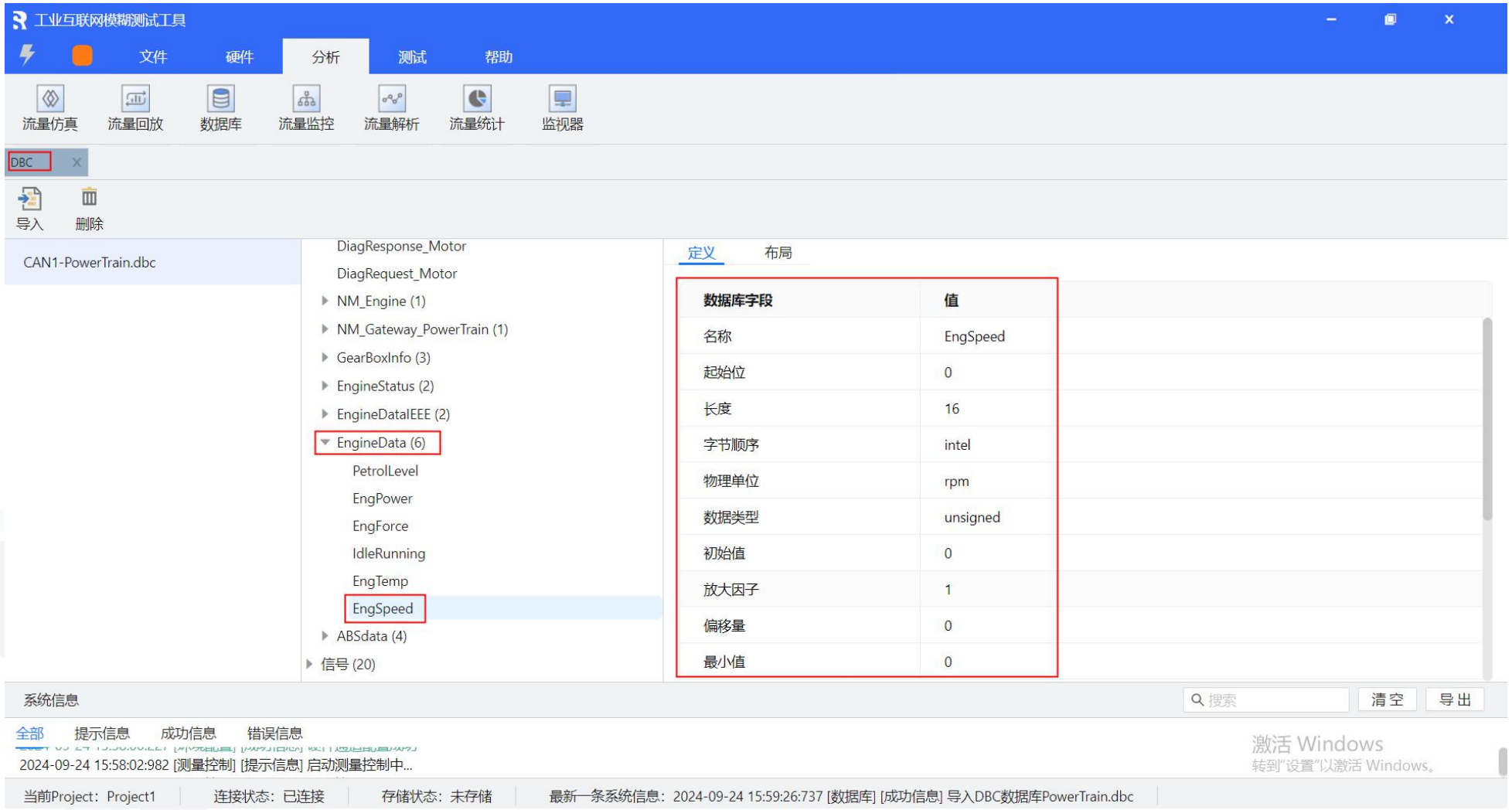
BEYOND TRUST / www.ticpsh.com
FUTURE INDUSTRY 为工业安全赋能

CAN安全实操演示



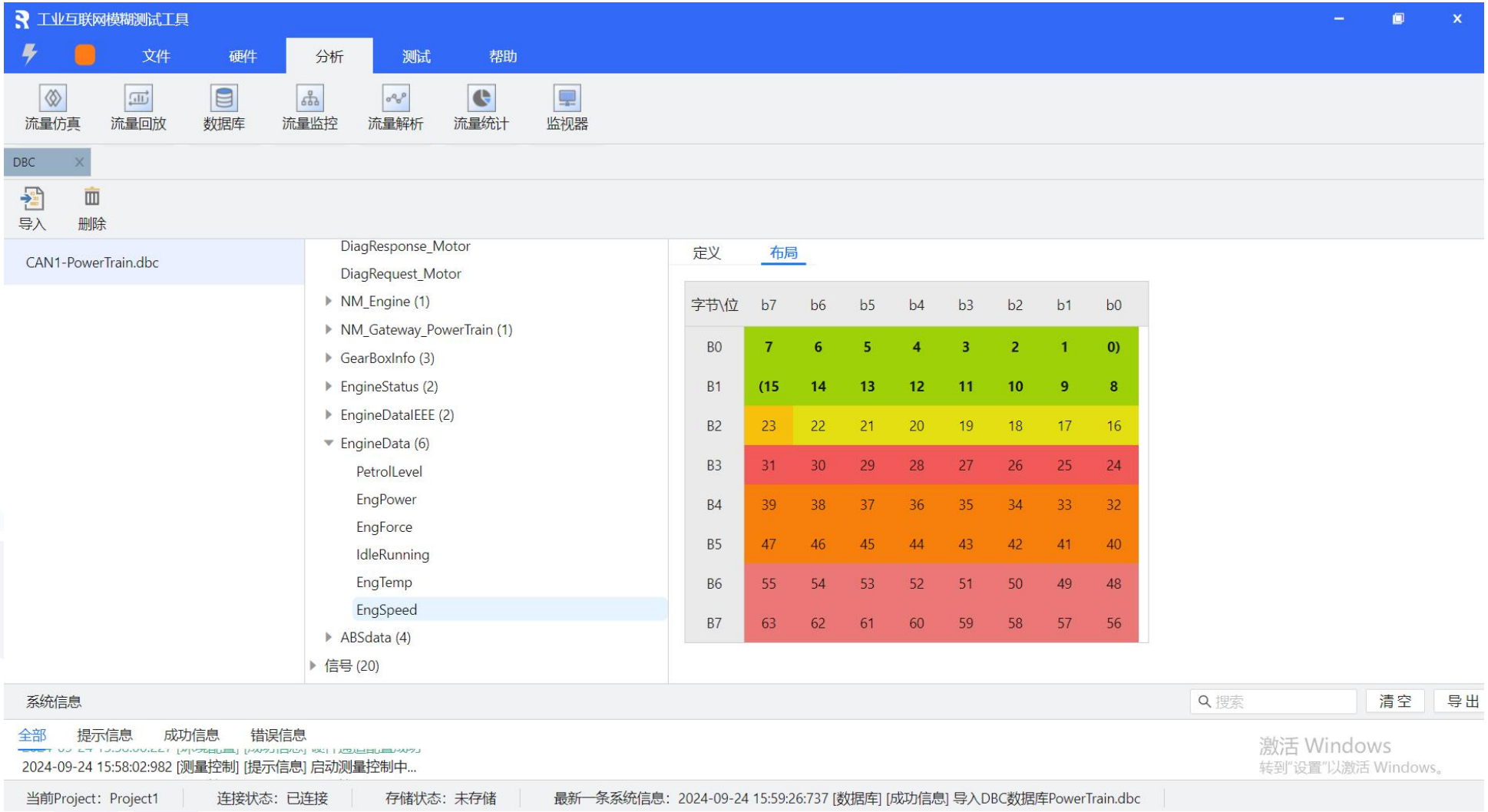
BEYOND TRUST FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

CAN安全实操演示



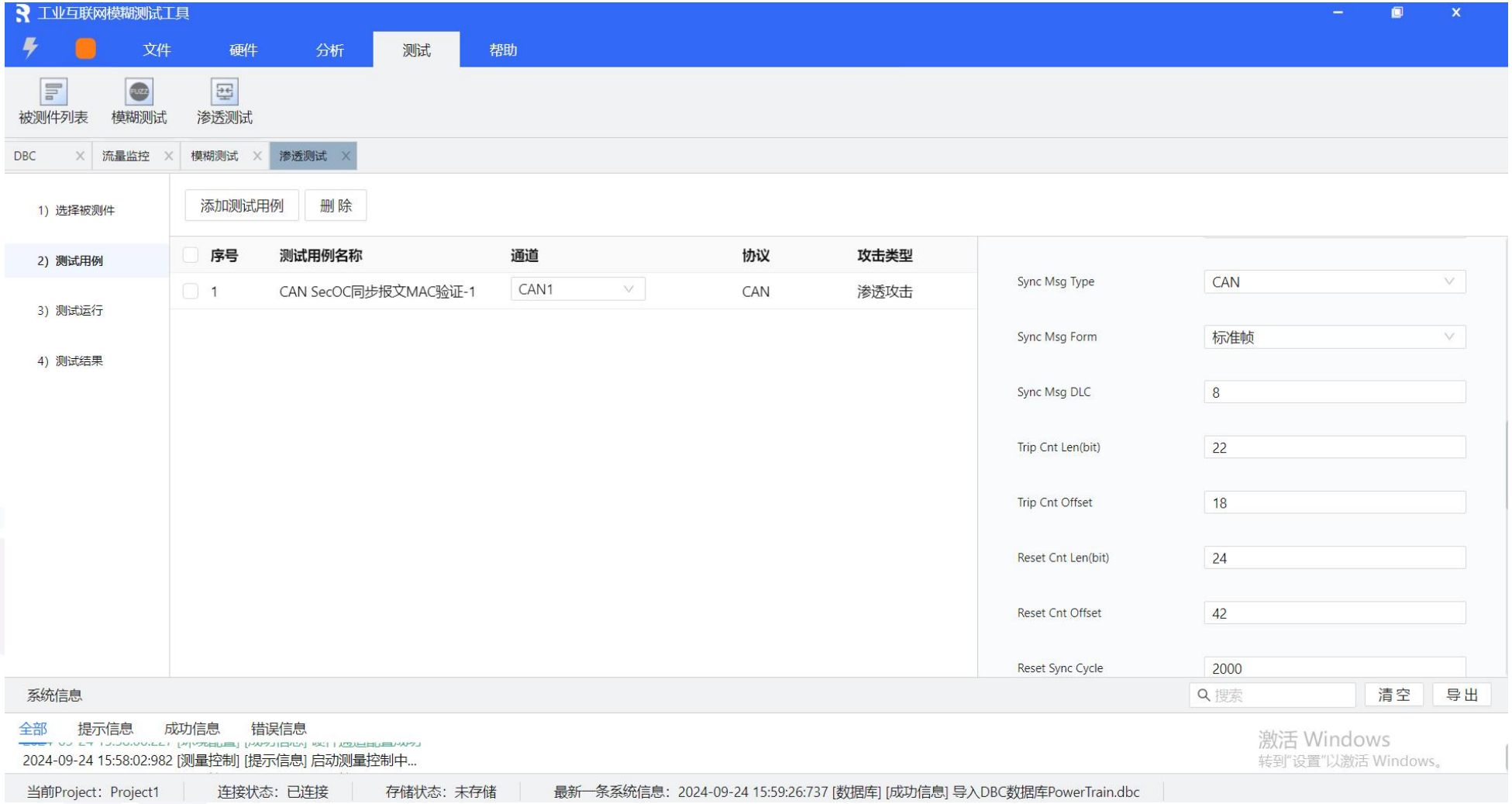
BEYOND TRUST / FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

CAN安全实操演示



BEYOND TRUST / FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

CAN安全实操演示



BEYOND TRUST / FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

PART 3

应用安全培训

Beyond Trust Future Industry

为工业安全赋能

应用安全比赛范围

apk文件：

- apk整体架构
- apk证书、签名、算法
- apk权限
- apk组件
- apk安全性

Android系统：

- Android系统整体架构
- Android权限

BEYOND TRUST FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

SmartRocket PeneX工具简介

汽车网络安全测试系统PeneX是一款支持对整车及车辆零部件及子系统实施网络安全测试的系统，其包含硬件安全、软件系统安全、车内通信及车外通信安全、数据安全四大安全测试系统。

- 支持合规性测试，包含国内外的法规及标准；
- 提供实验室部署方案及便携式工具箱方案，可按需灵活选择。



系统界面-首页看板

TICPSH 上海控安

PeneX Test Manager 汽车网络安全测试系统

En 中 控安

- 看板
- 测试工程
- 用例管理
  - 用例包
  - 用例库
- 漏洞库
- 工具库
- 被测件管理
- 机器管理
- 系统管理
  - 用户管理
  - FAQ管理
  - 备份管理
  - 系统配置
  - 证书许可
  - 审计管理

测试总览

工程数 356

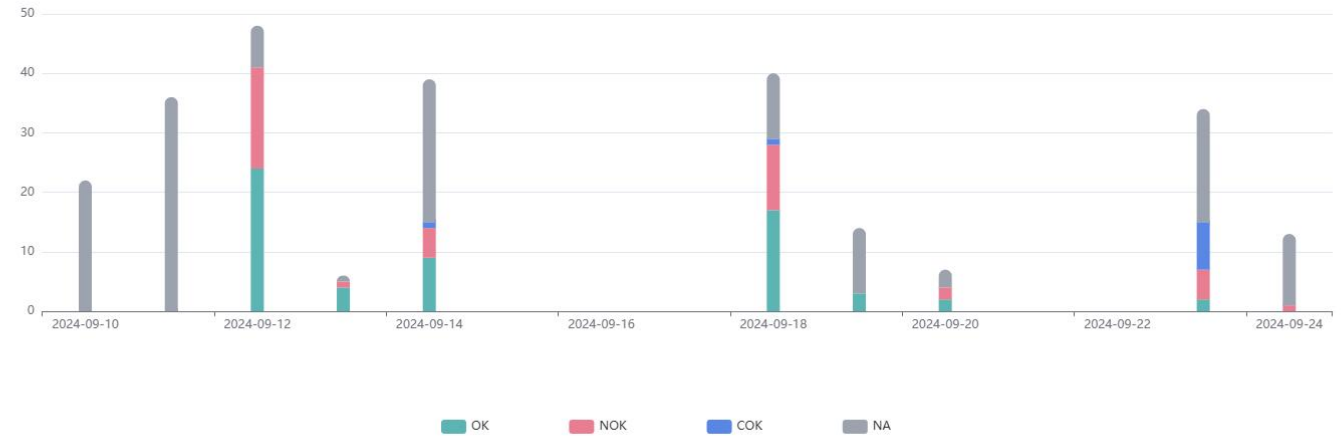
样品数 52

测试用例数 225

测试用例通过率 67.65%

工作追踪

近十五天 运行次数



工程近览

新建测试工程 查看更多

AI可信工程
无
测试用例通过率 0.00%

创建人：	控安	工程成员：	无
创建时间：	2024-09-24 14:36:05	总用例数：	30
最近执行时间：	/	OK/NOK/COK/NA：	0 / 0 / 0 / 0

CAN总线渗透测试
无
测试用例通过率 0.00%

软件检测
无
测试用例通过率 0.00%

FAQ

输入问题

PeneX的合规检测服务有哪些?

PeneX支持的标准有哪些?

系统界面-测试用例配置

看板
测试工程
用例管理
用例包
用例库
漏洞库
工具库
被测件管理
机器管理
系统管理
用户管理
FAQ管理
备份管理
系统配置
证书许可
审计管理

软件检测

测试用例配置

现有测试用例



测试用例库



保存

工程信息
测试用例配置
测试参数配置
被测件配置
测试执行
测试结果
测试报告

系统界面-测试参数配置

看板
测试工程
用例管理
用例包
用例库
漏洞库
工具库
被测件管理
机器管理
系统管理
用户管理
FAQ管理
备份管理
系统配置
证书许可
审计管理

软件检测

测试参数配置

全局参数配置

请输入关键字

参数名称	值	说明
暂无数据		

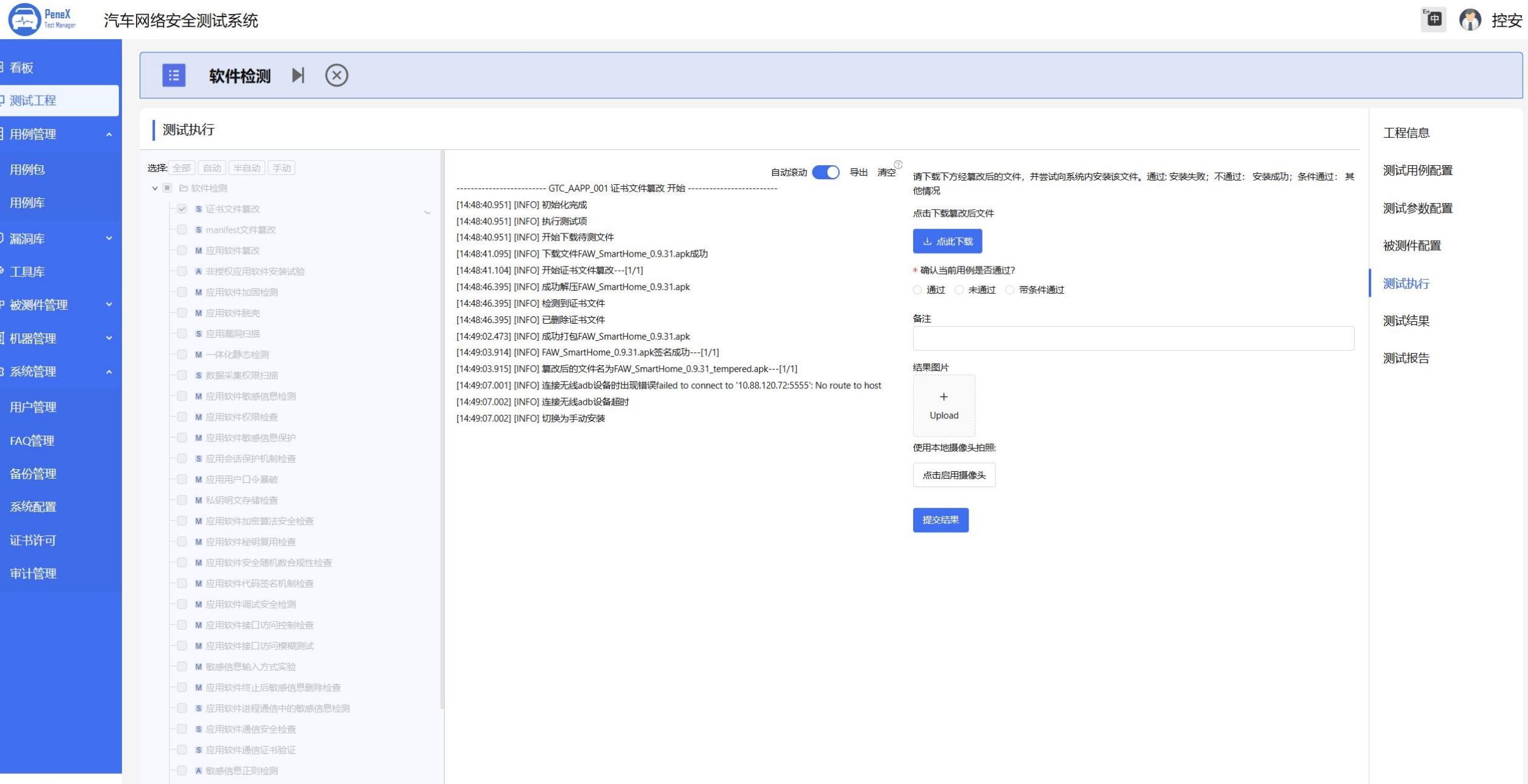
用例参数配置

请输入关键字

测试用例	参数名称	值	说明
证书文件篡改	篡改文件	上传	需要证书篡改的APK文件
证书文件篡改	安装模式	自动安装	篡改证书之后应用软件安装的模式
manifest文件篡改	篡改文件	上传	需要manifest篡改的APK文件
manifest文件篡改	安装模式	自动安装	篡改manifest之后应用软件安装的模式
非授权应用软件安装试验	非授权应用软件	上传	非授权应用软件
应用漏洞扫描	漏洞扫描文件	上传	需要进行漏洞扫描的APK文件
数据采集权限扫描	数据采集权限扫描文件	上传	需要进行数据采集权限扫描的APK文件
应用会话保护机制检查	抓包文件	上传	抓包文件
应用软件进程通信中的敏感信息检测	抓包文件	上传	抓包文件
应用软件通信安全检查	抓包文件	上传	抓包文件

工程信息
测试用例配置
测试参数配置
被测件配置
测试执行
测试结果
测试报告

系统界面-测试参数执行


PeneX Test Manager
汽车网络安全测试系统
控安
看板
测试工程
用例管理
用例包
用例库
漏洞库
工具库
被测件管理
机器管理
系统管理
用户管理
FAQ管理
备份管理
系统配置
证书许可
审计管理
软件检测
测试执行
选择: 全部 自动 半自动 手动
软件检测
证书文件篡改
manifest文件篡改
应用软件篡改
非授权应用软件安装试验
应用软件加固检测
应用软件脱壳
应用漏洞扫描
一体化静态检测
数据采集权限扫描
应用软件敏感信息检测
应用软件权限检查
应用软件敏感信息保护
应用会话保护机制检查
应用用户口令暴破
私钥明文存储检查
应用软件加密算法安全检查
应用软件秘钥复用检查
应用软件安全随机数合规性检查
应用软件代码签名机制检查
应用软件调试安全检测
应用软件接口访问控制检查
应用软件接口访问模糊测试
敏感信息输入方式实验
应用软件终止后敏感信息删除检查
应用软件进程通信中的敏感信息检测
应用软件通信安全检查
应用软件通信证书验证
敏感信息正则检测
自动滚动
导出
清空
---------- GTC_AAPP_001 证书文件篡改 开始 ----------
[14:48:40.951] [INFO] 初始化完成
[14:48:40.951] [INFO] 执行测试项
[14:48:40.951] [INFO] 开始下载待测文件
[14:48:41.095] [INFO] 下载文件FAW_SmartHome_0.9.31.apk成功
[14:48:41.104] [INFO] 开始证书文件篡改---[1/1]
[14:48:46.395] [INFO] 成功解压FAW_SmartHome_0.9.31.apk
[14:48:46.395] [INFO] 检测到证书文件
[14:48:46.395] [INFO] 已删除证书文件
[14:49:02.473] [INFO] 成功打包FAW_SmartHome_0.9.31.apk
[14:49:03.914] [INFO] FAW_SmartHome_0.9.31.apk签名成功---[1/1]
[14:49:03.915] [INFO] 篡改后的文件名为FAW_SmartHome_0.9.31_tempered.apk---[1/1]
[14:49:07.001] [INFO] 连接无线adb设备时出现错误failed to connect to '10.88.120.72:5555': No route to host
[14:49:07.002] [INFO] 连接无线adb设备超时
[14:49:07.002] [INFO] 切换为手动安装
请下载下方经篡改后的文件，并尝试向系统内安装该文件。通过: 安装失败；不通过： 安装成功；条件通过： 其他情况
点击下载篡改后文件
点此下载
* 确认当前用例是否通过?
通过
未通过
带条件通过
备注
结果图片
Upload
使用本地摄像头拍照:
点击启用摄像头
提交结果
工程信息
测试用例配置
测试参数配置
被测件配置
测试执行
测试结果
测试报告

系统界面-用例库

PeneX Test Manager 汽车网络安全测试系统

TICPSH 上海控安

En 中 控安

- 看板
- 测试工程
- 用例管理
  - 用例包
  - 用例库
- 漏洞库
- 工具库
- 被测件管理
- 机器管理
- 系统管理
  - 用户管理
  - FAQ管理
  - 备份管理
  - 系统配置
  - 证书许可
  - 审计管理

用例列表

新增用例

用例名称	用例类型	用例渠道	模块名称	用例标签	对应标准	风险等级	操作
应用软件篡改	M 手动	系统	软件安全	应用软件 × ＋添加标签	3	Low(1.8)	详情 安全风险分析
非授权应用软件安装试验	A 自动	系统	软件安全	＋添加标签	3	High(7.9)	详情 安全风险分析
应用软件加固检测	M 手动	系统	软件安全	＋添加标签	2	High(8.6)	详情 安全风险分析
应用软件脱壳	M 手动	系统	软件安全	＋添加标签	0	NA(/)	详情 安全风险分析
数据采集权限扫描	S 半自动	系统	软件安全	＋添加标签	1	Medium(6.8)	详情 安全风险分析
应用软件敏感信息检测	M 手动	系统	软件安全	＋添加标签	2	High(8.6)	详情 安全风险分析
应用软件权限检查	M 手动	系统	软件安全	＋添加标签	2	Medium(6)	详情 安全风险分析
应用软件敏感信息保护	M 手动	系统	软件安全	＋添加标签	1	Medium(6)	详情 安全风险分析
应用用户口令暴破	M 手动	系统	软件安全	＋添加标签	1	High(9.3)	详情 安全风险分析
私钥明文存储检查	M 手动	系统	软件安全	＋添加标签	1	High(8.6)	详情 安全风险分析

共 225 条 < 1 2 3 4 5 ··· 23 > 10 条/页

PART 4

AI可信学习参考

Beyond Trust Future Industry

为工业安全赋能

AI可信---参考资料

参考资料：

- FGSM-TensorFlow官方实现
- 对抗性攻击方法综述论文
- 对抗攻击的12种攻击方法和15种防御方法
- 15种对抗攻击的防御方法
- 一种可以物理实现的脸部对抗性特征生成方法

BEYOND TRUST FUTURE INDUSTRY www.ticpsh.com 为工业安全赋能

TICPSH
上海控安

THANKS

Beyond Trust Future Industry

为工业安全赋能